

M3 - Progetto fine modulo

Analisi delle vulnerabilità e azioni di rimedio

Indice:

1. Executive Summary	p. 2
2. Metodologie e Strumenti	p. 2
3. Scansione Iniziale	p. 4
4. Analisi delle Vulnerabilità Selezionate e Implementazione delle Remediations	p. 7
5. Scansione Post-Remediation	p. 14
6. Conclusioni	p. 15

1. Executive Summary

Il presente documento illustra le attività di scansione e analisi delle vulnerabilità effettuate sulla macchina target Metasploitable 2. L'obiettivo è identificare le falle critiche, implementare strategie di mitigazione (remediation) e verificare l'efficacia degli interventi attraverso una scansione di controllo post-remediation.

2. Metodologia e Strumenti

L'analisi è stata condotta in un ambiente virtuale isolato utilizzando i seguenti strumenti:

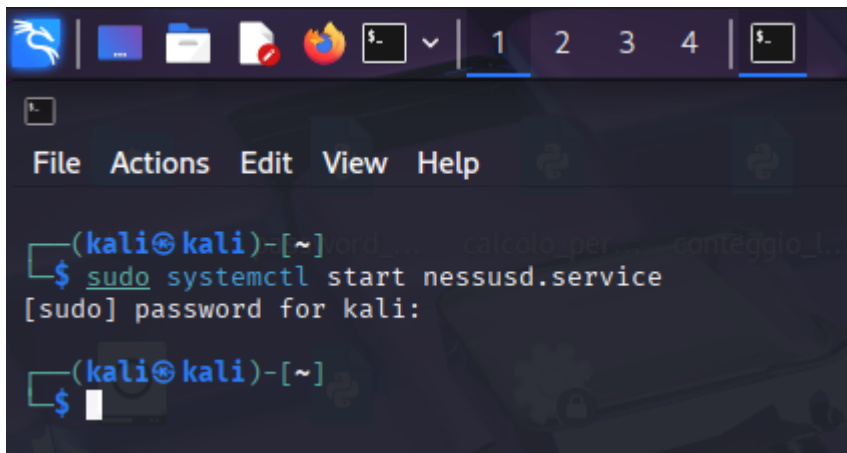
- **Host:** Kali Linux.
- **Target:** Metasploitable2.
- **Software di analisi:** Nessus (installato sulla macchina Kali Linux).

Prima di avviare la scansione, è necessario eseguire i seguenti passaggi per configurare l'ambiente:

- **Verifica della connettività:** dopo aver avviato entrambe le macchine, tramite il comando "ping" da Kali verso l'IP di Meta, si è verificato che entrambe le macchine fossero collegate sulla stessa rete.

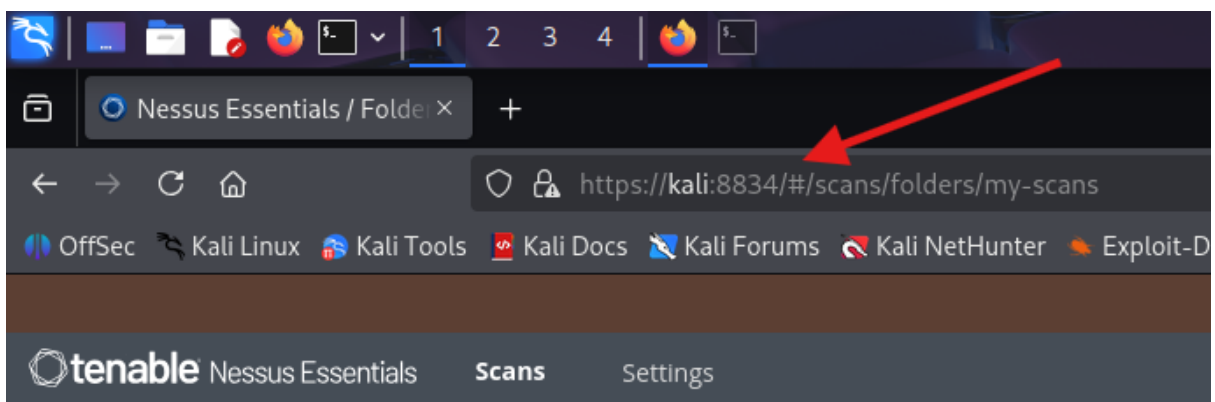
```
(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=16.2 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=15.7 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=1.49 ms
^C
— 192.168.50.101 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2008ms
rtt min/avg/max/mdev = 1.491/11.138/16.227/6.825 ms
```

- **Attivazione dello scanner:** tramite il terminale di Kali, con il comando `sudo systemctl start nessusd.service` , si avvia il servizio di Nessus.



```
(kali㉿kali)-[~]  
$ sudo systemctl start nessusd.service  
[sudo] password for kali:  
(kali㉿kali)-[~]  
$
```

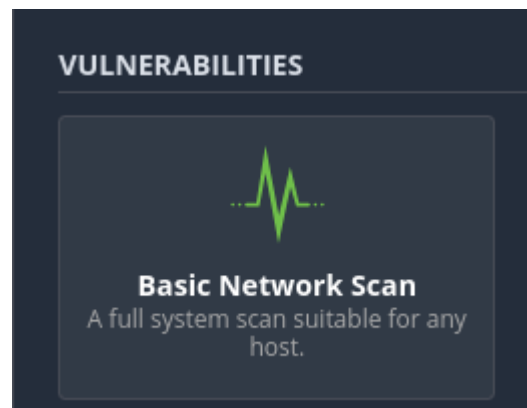
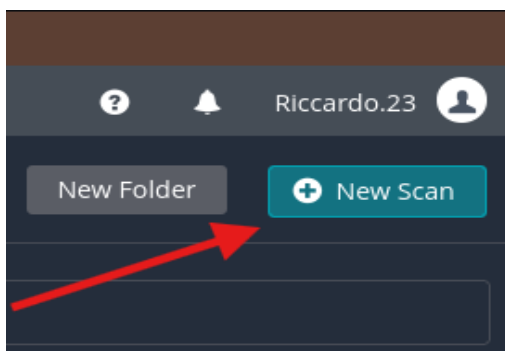
- **Accesso all'interfaccia Web di Nessus:** attraverso l'URL <https://kali:8834> , si effettua l'accesso all'interfaccia Web di Nessus sulla porta 8834.



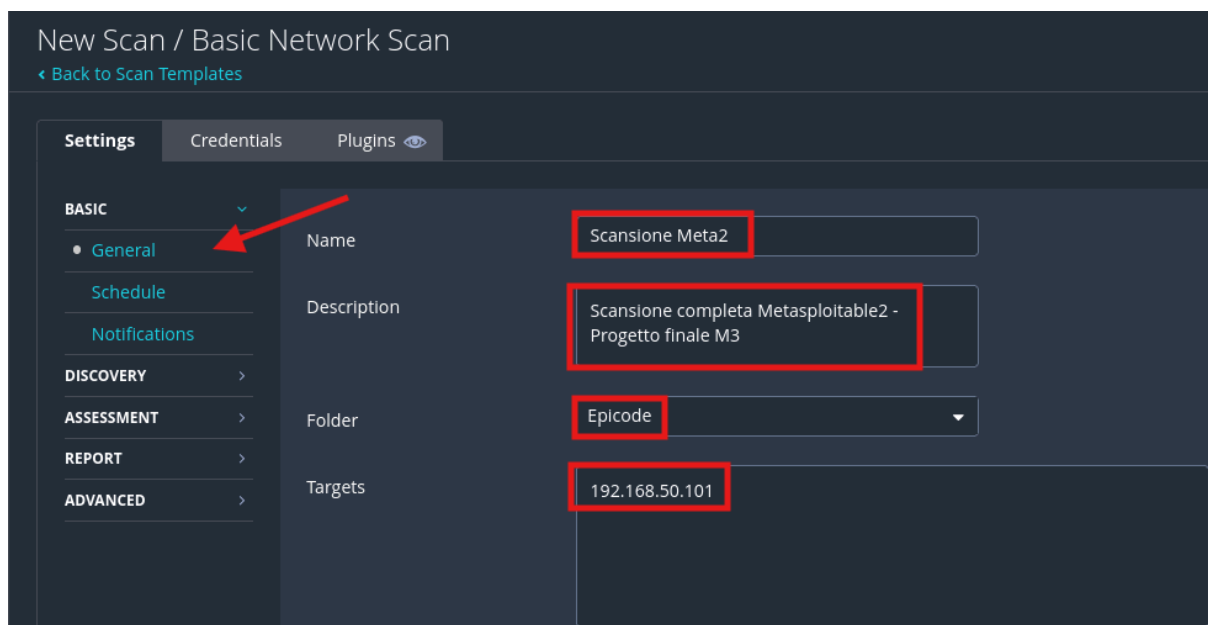
3. Scansione Iniziale

Una volta verificata la connessione tra le macchine e dopo aver attivato il servizio di Nessus, si procede con la configurazione della scansione. I passaggi sono i seguenti:

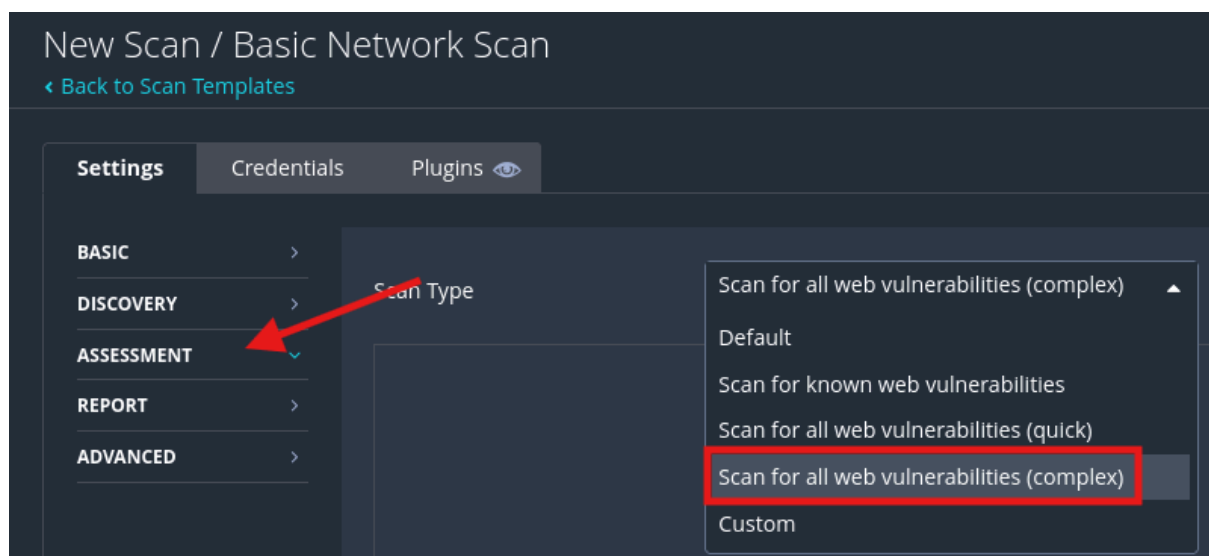
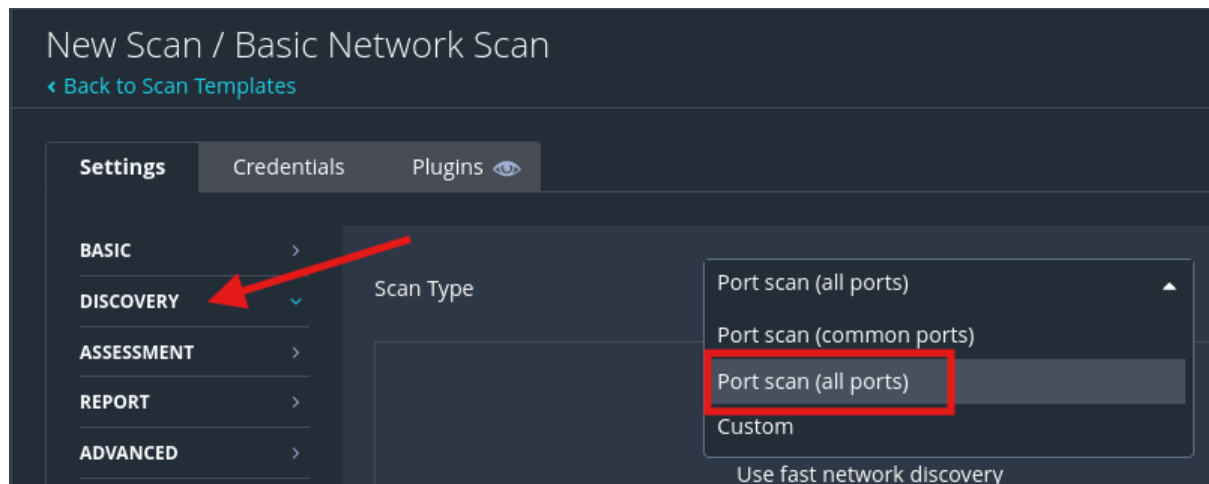
- **Creazione nuova scansione:** si procede alla creazione di una nuova scansione attraverso il tasto “**New Scan**” e successivamente si seleziona l’opzione “**Basic Network Scan**” .



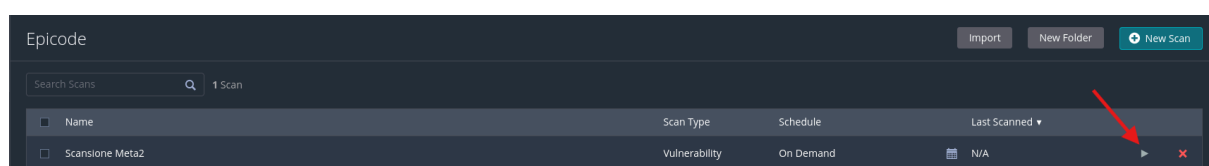
- **Configurazione Base (BASIC):** è stata creata una nuova scansione denominata “Scansione Meta2”, all’interno della cartella “Epicode”, che abbia come target l’indirizzo IP di Metasploitable2, ovvero 192.168.50.101 .



- **Discovery e Assessment:** Per garantire la massima copertura, la scansione è stata configurata per analizzare tutte le porte (**all ports**), evitando di limitarsi a quelle standard. È stata inoltre attivata l'opzione **“Scan for all web vulnerabilities (complex)”**. Sebbene questa modalità richieda tempi di esecuzione più lunghi, è indispensabile per individuare vulnerabilità più nascoste.

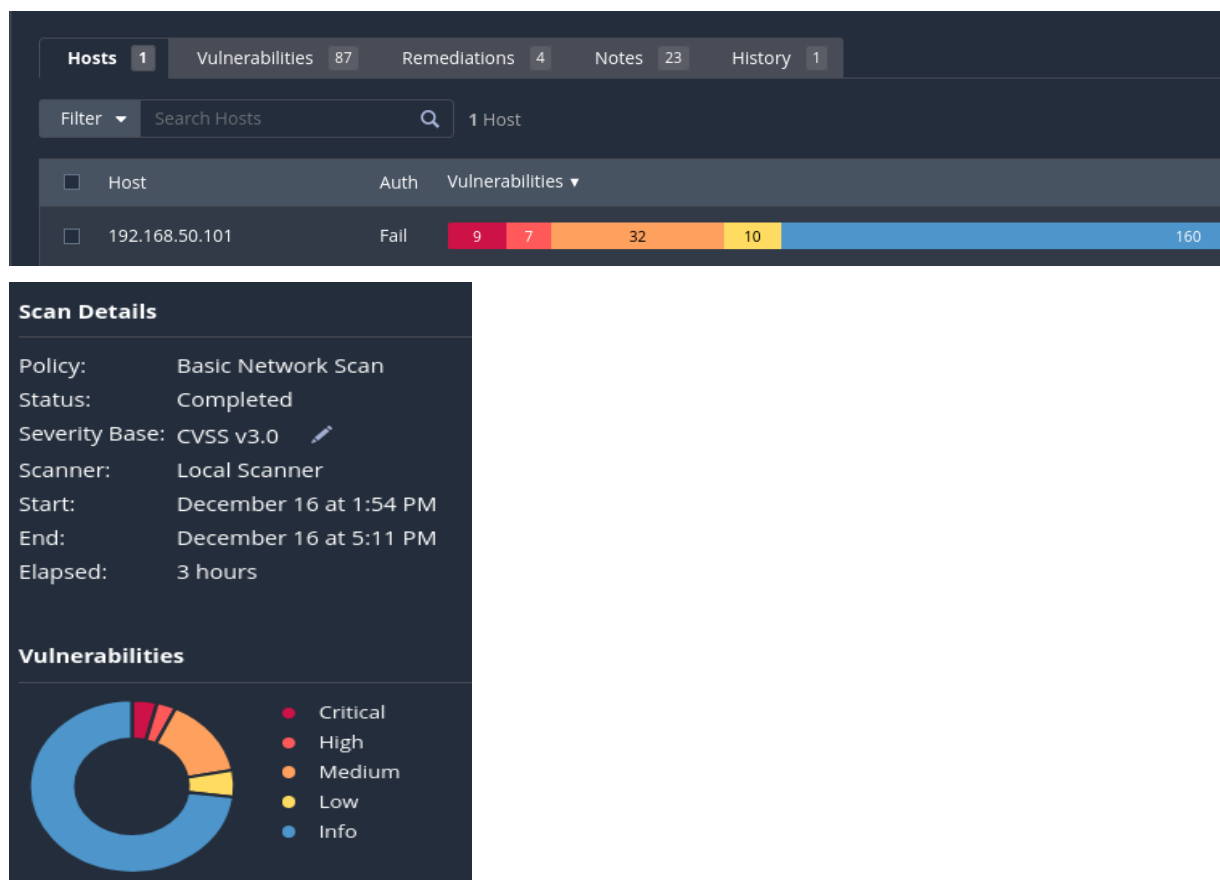


- **Avvio scansione:** Dopo aver configurato la scansione, si procede all'avvio attraverso il pulsante "play".



Al termine dell'attività di scansione, durata approssimativamente 3 ore, Nessus ha fornito quadro completo delle vulnerabilità rilevate sul target Metasploitable2. I grafici mostrano un totale di **87 vulnerabilità rilevate**, suddivise sulla base della loro **"criticità"**:

- **"Critical"** : sono vulnerabilità molto rischiose poiché permettono l'esecuzione di codice remoto o il controllo del sistema.
- **"High"** : anch'esse rischiose poiché potrebbero esporre dati sensibili.
- **"Medium"** : riguardano spesso problemi di configurazione o servizi che potrebbero esporre informazioni utili ad un potenziale attaccante.
- **"Low"** : vulnerabilità meno gravi che spesso richiedono la presenza di altre vulnerabilità per essere sfruttate.
- **"Info"** : riguardano servizi attivi e porte aperte che non costituiscono pericoli immediati ma aiutano nell'analisi del target.



4. Analisi delle Vulnerabilità Selezionate e Implementazione delle Remediations

La prima vulnerabilità “**Critical**” selezionata è la seguente:

☐

CRITICAL

9.8

Bind Shell Backdoor Detection

CRITICAL Bind Shell Backdoor Detection

Description
A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution
Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```
Nessus was able to execute the command "id" using the
following request :

This produced the following truncated output (limited to 10 lines) :
..... snip .....
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
..... snip .....
```

To see debug logs, please visit individual host

Port ▲	Hosts
1524 / tcp / wild_shell	192.168.50.101

Tale vulnerabilità indica che nel sistema target è presente una shell in ascolto su una porta remota (**1524**) che non richiede alcuna autenticazione. Questo permette a un utente malintenzionato di ottenere il controllo totale del sistema come amministratore (**root**).

Remediation:

Per questa specifica vulnerabilità, l'azione di rimedio consiste nel terminare il processo malevolo attraverso i seguenti passaggi:

- Accedendo alla macchina target Meta2, si possono ottenere i **privilegi di amministratore** attraverso il comando “**sudo su**”.

- Individuazione del processo in esecuzione sulla porta **1524**, tramite il comando: **lsof -i :1524** .
- Identificato il relativo **PID**, si procede alla chiusura forzata del **processo in esecuzione** attraverso il comando: **Kill -9 4647** . In questo modo si termina il servizio che gestisce la **backdoor** sulla porta 1524.

```
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin# lsof -i :1524
COMMAND  PID USER  FD   TYPE DEVICE SIZE NODE NAME
xinetd   4647 root   12u  IPv4  12464      TCP *:ingreslock (LISTEN)
root@metasploitable:/home/msfadmin# kill -9 4647
root@metasploitable:/home/msfadmin# lsof -i :1524
root@metasploitable:/home/msfadmin# netstat -tln | grep 1524
root@metasploitable:/home/msfadmin#
```

La corretta chiusura del processo è confermata attraverso una doppia verifica:

- Su **Meta2**: l'assenza di output ai comandi “ **lsof -i :1524** ” e “ **netstat -tln | grep 1524** ” indica che nessun servizio è in esecuzione su quella porta.
- Su **Kali**: utilizzando **nmap**, con il comando “ **nmap -p 1524 192.168.50.101** ”, si può notare che ora la porta **1524** risulta chiusa.

```
(kali㉿kali)-[~]
$ nmap -p 1524 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-22 04:17 EST
Nmap scan report for 192.168.50.101
Host is up (0.0097s latency).

PORT      STATE SERVICE
1524/tcp  closed ingreslock
MAC Address: 08:00:27:34:69:32 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.23 seconds

(kali㉿kali)-[~]
$
```


La seconda vulnerabilità “Critical” selezionata è la seguente:

☐ **CRITICAL** 10.0 * VNC Server 'password' Password

CRITICAL VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

```
Nessus logged in using a password of "password".
```

To see debug logs, please visit individual host

Port ▲	Hosts
5900 / tcp / vnc	192.168.50.101

Questa vulnerabilità indica che il server VNC in esecuzione sul target (**porta 5900**) è protetto da una password estremamente debole (“password”). Un potenziale attaccante, tramite un attacco Brute-Force, potrebbe facilmente autenticarsi senza autorizzazione e prendere il controllo del sistema.

Remediation:

Come suggerito da Nessus stesso, la soluzione consigliata è quella di impostare una password più sicura. Per fare ciò è necessario eseguire i seguenti passaggi sulla macchina target:

- Attraverso il comando “ **ps aux | grep vnc** ”, si individua il processo del server VNC in esecuzione e il relativo **PID (4792)**.
- Per poter applicare le modifiche alla password, occorre terminare il processo tramite il comando “ **kill -9 4792** ” e successivamente lanciare il comando “ **vncpasswd** ” .
- Si prosegue impostando la nuova password (**Hasbulla23**)
- Infine, attraverso il comando “ **vncserver :0** ” si riavvia il servizio VNC.

```

root@metasploitable:/home/msfadmin# ps aux | grep vnc
root      4792   0.4  2.3 14024 12016 ?        S    04:05   0:19 Xtightvnc :0 -d
esktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      4801   0.0  0.2   2724   1188 ?        S    04:05   0:00 /bin/sh /root/.
vnc/xstartup
root      5038   0.0  0.1   3004    752 tty1      R+   05:18   0:00 grep vnc
root@metasploitable:/home/msfadmin# kill -9 4792
root@metasploitable:/home/msfadmin# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:/home/msfadmin# vncserver :0

```

Grazie a questa operazione, il server VNC non è più accessibile con la password di default.

La terza vulnerabilità “**Critical**” selezionata è la seguente:

☐

CRITICAL

9.8

9.0

0.9439

Apache PHP-CGI Remote Code Execution

CRITICAL Apache PHP-CGI Remote Code Execution

Description

The PHP installation on the remote web server contains a flaw that could allow a remote attacker to pass command-line arguments as part of a query string to the PHP-CGI program. This could be abused to execute arbitrary code, reveal PHP source code, cause a system crash, etc.

Solution

Upgrade to PHP 5.3.13 / 5.4.3 or later.

Output

```

Nessus was able to verify the issue exists using the following request :

----- snip -----
POST /cgi-bin/php?%2D%64+%61%6C%6F%77%5F%75%72%6C%5F%69%6B%63%6C%75%64%65%3D%6F%6E+%2D%64+%73%61%66%65%5F%6D%6F%64%65%3D%6F%66%66+%2D%64+%
73%75%68%6F%73%69%6E%2E%73%69%6D%75%6C%61%74%69%6F%6E%3D%6F%6E+%2D%64+%64%69%73%61%62%6C%65%5F%66%75%6E%63%74%69%6F%6E%73%3D%22+%2D%64+%
6F%70%65%6E%5F%62%61%73%65%64%69%72%3D%6E%6F%6E%65+%2D%64+%61%75%74%6F%5F%70%72%65%70%65%6E%64%5F%66%69%6C%65%3D%70%68%70%3A%2F%69%6E%70%75%74+%
2D%64+%63%67%69%2E%66%6F%72%63%65%5F%72%65%64%69%72%65%63%74%3D%30+%2D%64+%
63%67%69%2E%72%65%64%69%72%65%63%74%5F%73%74%61%74%75%73%5F%65%6E%76%3D%30+%2D%6E HTTP/1.1
Host: 192.168.50.101
more...

```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	192.168.50.101

Questa vulnerabilità indica che l'installazione di **PHP** sul server web remoto può permettere a un attaccante di passare argomenti a riga di comando, eseguire codice oppure causare il crash del sistema.

Remediation:

Nessus ci suggerisce di effettuare un upgrade a PHP 5.3.13 / 5.4.3 o successivi ma, poiché Metasploitable 2 è un ambiente di test, non è consigliabile aggiornare i pacchetti.

La remediation alternativa consiste nel disabilitare il modulo CGI vulnerabile o arrestare il servizio web Apache che lo espone attraverso i seguenti passaggi:

- Si procede arrestando il server web Apache tramite il comando: “ **sudo /etc/init.d/apache2 stop** ” .
- Successivamente, attraverso il comando “ **sudo update-rc -f apache2 remove** ”, si disabilita l'avvio automatico del Server Web ad ogni riavvio della macchina Metasploitable2
- Infine, tramite il comando “ **netstat -ant | grep 80** ”, si verifica l'assenza di servizi attivi sulla porta 80.

```
root@metasploitable:/home/msfadmin# sudo /etc/init.d/apache2 stop
* Stopping web server apache2                                     [ OK ]
root@metasploitable:/home/msfadmin# sudo update-rc.d -f apache2 remove
Removing any system startup links for /etc/init.d/apache2 ...
/etc/rc0.d/K09apache2
/etc/rc1.d/K09apache2
/etc/rc2.d/S91apache2
/etc/rc3.d/S91apache2
/etc/rc4.d/S91apache2
/etc/rc5.d/S91apache2
/etc/rc6.d/K09apache2
root@metasploitable:/home/msfadmin# netstat -ant | grep 80
tcp        0      0 0.0.0.0:8009          0.0.0.0:*             LISTEN
tcp        0      0 0.0.0.0:8180          0.0.0.0:*             LISTEN
root@metasploitable:/home/msfadmin#
```

La quarta vulnerabilità “**Critical**” selezionata è la seguente:

☐ **CRITICAL** 10.0 * 5.1 0.0165 Debian OpenSSH/OpenSSL Package Random Number Generator Wea...

CRITICAL Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Description

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

See Also

<http://www.nessus.org/u?107f9bdc>
<http://www.nessus.org/u?f14f4224>

Output

No output recorded.

To see debug logs, please visit individual host

Port ▲	Hosts
5432 / tcp / postgresql	192.168.50.101
25 / tcp / smtp	192.168.50.101

La presente vulnerabilità riguarda la sicurezza del server: la crittografia. Un potenziale attaccante può pre-calcolare le chiavi possibili e usarle per decifrare connessioni sicure o per accedere al server senza autorizzazione (**Man-In-The-Middle**).

In particolare, Nessus, ha rilevato questa vulnerabilità sui servizi “**PostgreSQL**” e “**SMTP**” sulle porte **5432** e **25**.

Remediation:

In un ambiente reale, si dovrebbe procedere all'aggiornamento del sistema operativo. Su **Metasploitable 2**, essendo parte del laboratorio virtuale, si procede alla disabilitazione dei servizi che espongono queste chiavi deboli nel seguente modo:

- Si verifica che le porte 5432 e 25 siano effettivamente aperte attraverso il comando: **"netstat -ant | grep -E "5432|25"** .
- Successivamente si procede all' arresto di **PostgreSQL (porta 5432)** e al suo possibile avvio ad ogni riavvio della macchina Meta2, attraverso i relativi comandi: **" sudo /etc/init.d/postgresql-8.3 stop "** e **" sudo update-rc.d -f postgresql-8.3 remove "** .
- Si ripete il procedimento con **Postfix (porta 25)** utilizzando i seguenti comandi: **" sudo /etc/init.d/postfix stop "** e **" sudo update-rc.d -f postfix remove "** .
- Infine si esegue nuovamente il controllo dei servizi attivi sulle porte 5432 e 25, con il comando: **" netstat -ant | grep -E "5432|25" "**.
L'output, non generando risultati, conferma la rimozione dei servizi e dunque la neutralizzazione della vulnerabilità.

```

root@metasploitable:/home/msfadmin# netstat -ant | grep -E "5432|25"
tcp        0      0 0.0.0.0:5432        0.0.0.0:*          LISTEN
tcp        0      0 0.0.0.0:25         0.0.0.0:*          LISTEN
tcp6       0      0 :::5432            :::*                LISTEN
root@metasploitable:/home/msfadmin# sudo /etc/init.d/postgresql-8.3 stop
* Stopping PostgreSQL 8.3 database server [ OK ]
root@metasploitable:/home/msfadmin# sudo update-rc.d -f postgresql-8.3 remove
Removing any system startup links for /etc/init.d/postgresql-8.3 ...
/etc/rc0.d/K21postgresql-8.3
/etc/rc1.d/K21postgresql-8.3
/etc/rc2.d/S19postgresql-8.3
/etc/rc3.d/S19postgresql-8.3
/etc/rc4.d/S19postgresql-8.3
/etc/rc5.d/S19postgresql-8.3
/etc/rc6.d/K21postgresql-8.3
root@metasploitable:/home/msfadmin# _

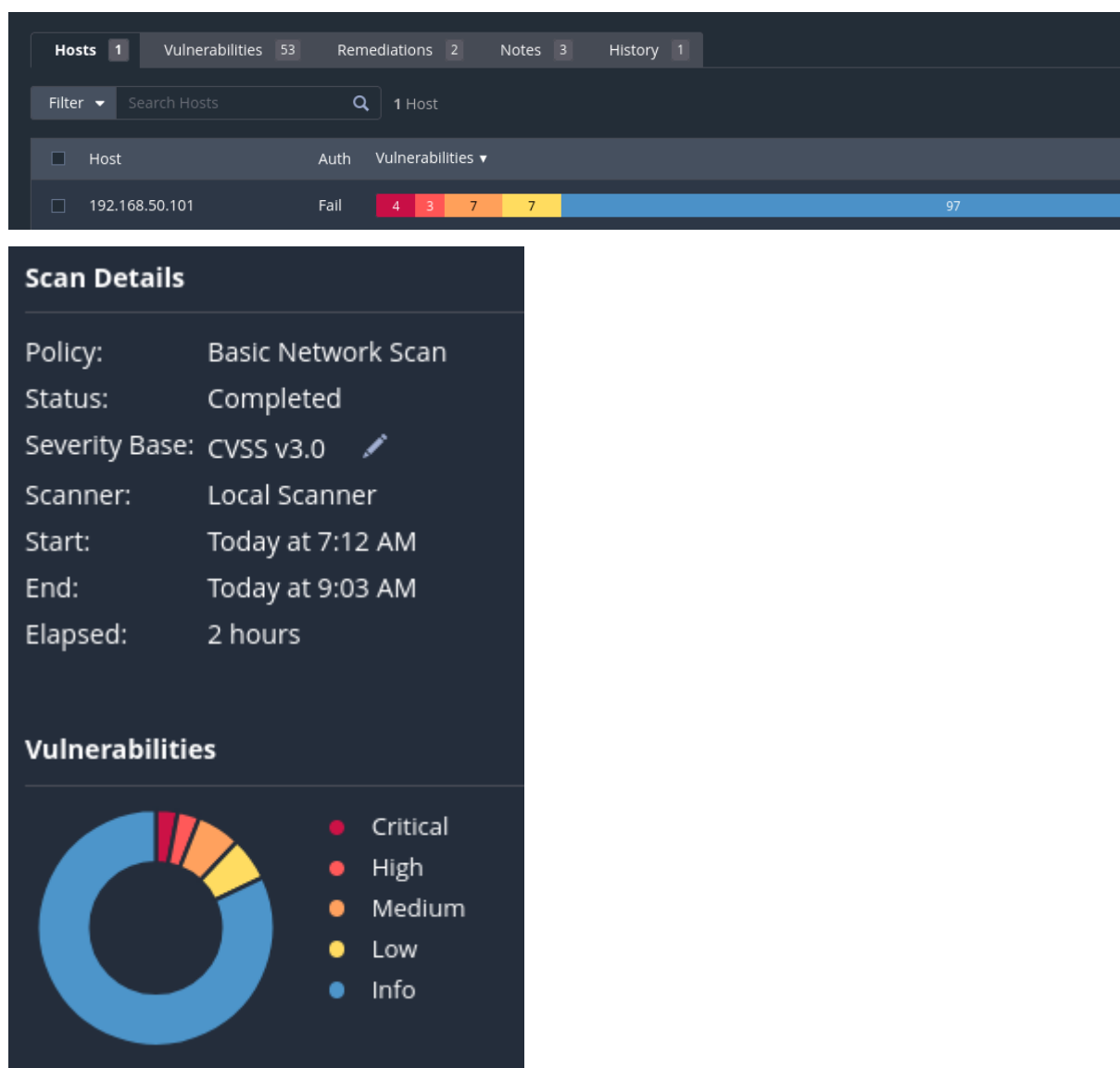
root@metasploitable:/home/msfadmin# sudo /etc/init.d/postfix stop
* Stopping Postfix Mail Transport Agent postfix [ OK ]
root@metasploitable:/home/msfadmin# sudo update-rc.d -f postfix remove
Removing any system startup links for /etc/init.d/postfix ...
/etc/rc0.d/K20postfix
/etc/rc1.d/K20postfix
/etc/rc2.d/S20postfix
/etc/rc3.d/S20postfix
/etc/rc4.d/S20postfix
/etc/rc5.d/S20postfix
/etc/rc6.d/K20postfix
root@metasploitable:/home/msfadmin# netstat -ant | grep -E "5432|25"
root@metasploitable:/home/msfadmin#

```

Così facendo, spegnendo il database **PostgreSQL**, è impossibile intercettare dati sensibili tramite certificati SSL deboli e, disattivando **STMP**, si è impedito l'uso di chiavi crittografiche prevedibili per la posta elettronica.

5. Scansione Post-Remediation

Dopo aver effettuato le remediation sopra riportate, si è proceduto ad effettuare una nuova scansione sul target Metasploitable con il fine di individuare eventuali miglioramenti riguardo le vulnerabilità individuate.



Coma mostrato nei grafici dei risultati della scansione finale, si evince una notevole diminuzione delle vulnerabilità totali (da 87 a 53), dunque, una riduzione notevole della superficie d'attacco. Nello specifico:

- le vulnerabilità **Critical** sono diminuite da 9 a 4.
- le vulnerabilità **High** sono diminuite da 7 a 3.

- le vulnerabilità “Medium” sono diminuite da 32 a 7
- le vulnerabilità “Low” sono diminuite da 10 a 7
- le “Info” sono diminuite da 160 a 97

6. Conclusioni

Le remediation apportate hanno ridotto le vulnerabilità totali da 87 a 52. La disattivazione di servizi obsoleti (Apache, PostgreSQL ecc...) e la protezione di VNC hanno eliminato i principali vettori di accesso remoto e di esecuzione di codice, dunque, la superficie di attacco, risulta essere più ridotta.

Riccardo Ricci

Roma, 22/12/2025